AEGIS BANK

Penetration Testing Standard

Enterprise AI Decision & Knowledge Platform for Modern Banking

---

Document Information

Field	Details
Document Title	Penetration Testing Standard
Document ID	**AB-CYB-010**
Department	Cybersecurity & Security Assurance
Version	v1.2
Last Updated	July 24, 2026
Document Owner	Penetration Testing Lead
Classification	Restricted
Review Date	July 24, 2027
Approved By	**Sami Khan – Chief Executive Officer (CEO)**

Confidentiality Notice

This Penetration Testing Standard establishes the requirements for conducting authorized security testing of Aegis Bank's information systems, applications, cloud infrastructure, APIs, and AI platforms.

The objective is to proactively identify exploitable security weaknesses before they can be leveraged by malicious actors.

Unauthorized distribution of this document is prohibited.

Table of Contents

1. Purpose

2. Scope
3. Objectives
4. Testing Principles
5. Testing Types
6. Penetration Testing Methodology
7. Testing Frequency
8. Rules of Engagement
9. AI & RAG Security Testing
10. Reporting Requirements
11. Remediation & Verification
12. Roles & Responsibilities
13. Practical Examples
14. Frequently Asked Questions
15. Revision History
16. Document Approval

---

1. Purpose

The purpose of this standard is to define a structured approach for authorized penetration testing across Aegis Bank.

Objectives include:

- Identify exploitable vulnerabilities.
- Validate security controls.
- Reduce cyber risk.
- Improve regulatory compliance.
- Strengthen resilience.

---

2. Scope

This standard applies to:

- Core Banking Systems
- Internet Banking
- Mobile Banking
- APIs
- Cloud Infrastructure
- Internal Networks
- Firewalls
- Databases
- AI Platform (Aegis AI OS)
- Employee Portals

---

3. Objectives

Penetration testing aims to:

- Simulate real-world attacks.
- Validate existing security controls.
- Assess exploitability.
- Identify configuration weaknesses.
- Recommend remediation.

---

4. Testing Principles

All testing must be:

- Authorized.
- Documented.
- Risk-controlled.

- Non-destructive.
- Confidential.
- Traceable.

Testing must avoid unnecessary disruption to production services unless explicitly approved.

---

5. Testing Types

Type	Description
External Penetration Test	Internet-facing systems
Internal Penetration Test	Internal corporate network
Web Application Test	Banking portals and applications
API Security Test	REST/GraphQL APIs
Mobile Application Test	Android & iOS banking apps
Cloud Security Assessment	Cloud infrastructure
Wireless Security Test	Corporate Wi-Fi
AI Security Assessment	LLMs, RAG, prompt security

---

6. Penetration Testing Methodology

Testing follows this lifecycle:

Planning

↓

Reconnaissance

↓

Scanning

↓

Exploitation

↓

Privilege Escalation

↓

Post-Exploitation

↓

Reporting

↓

Remediation Validation

Activities include:

- Information gathering.
- Vulnerability identification.
- Controlled exploitation.

- Impact assessment.
- Documentation.

---

7. Testing Frequency

Asset	Minimum Frequency
Internet Banking	Quarterly
Mobile Banking	Semi-Annual
Core Banking	Annual
APIs	Quarterly
Cloud Infrastructure	Quarterly
AI Platform	Quarterly
External Infrastructure	Annual
Major System Changes	Before Production Release

Additional testing is required after major upgrades or significant security incidents.

---

8. Rules of Engagement

Before testing:

- Obtain written authorization.
- Define testing scope.
- Identify in-scope assets.
- Schedule testing windows.
- Notify stakeholders where appropriate.

During testing:

- Preserve customer data.
- Minimize service disruption.

- Avoid destructive payloads.
- Record all activities.

---

9. AI & RAG Security Testing

Security assessments include:

Prompt Injection Testing

Attempt to bypass AI instructions using malicious prompts.

Retrieval Authorization Testing

Verify users cannot retrieve documents outside their permissions.

Hallucination Assessment

Evaluate unsupported or fabricated AI responses.

Knowledge Base Integrity

Ensure enterprise documents cannot be tampered with.

Model Configuration Review

Validate secure deployment settings and access controls.

---

10. Reporting Requirements

Every penetration test report must include:

- Executive Summary.
- Scope.
- Methodology.
- Findings.
- Risk Ratings.
- Proof of Concept (where appropriate).
- Business Impact.
- Remediation Recommendations.

Severity levels:

Severity	Description
Critical	Immediate exploitation risk
High	Significant business impact
Medium	Moderate security weakness
Low	Minor issue or best practice

---

11. Remediation & Verification

Remediation process:

Finding Reported

↓

Risk Assessment

↓

Corrective Action

↓

Patch / Configuration Update

↓

Retesting

↓

Closure

Critical findings must be remediated according to the Vulnerability Management Policy.

---

12. Roles & Responsibilities

Role	Responsibility
CISO	Executive oversight
Penetration Testing Team	Conduct assessments
IT Operations	Implement infrastructure fixes
Development Teams	Resolve application issues
AI Engineering	Address AI-related findings
Risk Management	Track remediation progress

---

13. Practical Examples

Example 1 — SQL Injection

Testing identifies an SQL injection vulnerability in an internal application.

Actions:

1. Issue documented.
2. Development team fixes input validation.
3. Application retested.
4. Finding closed.

Example 2 — Prompt Injection

Security team attempts to override AI instructions using crafted prompts.

Actions:

1. Weakness identified.
2. Prompt filtering improved.
3. Access controls strengthened.
4. AI retested.

Example 3 — API Authorization

Assessment reveals insufficient authorization checks.

Actions:

1. Access control updated.
2. Authentication validated.
3. APIs retested.
4. Security approval granted.

---

14. Frequently Asked Questions (FAQs)

Q1. Why perform penetration testing?

To identify exploitable weaknesses before attackers do.

Q2. Is penetration testing the same as vulnerability scanning?

No. Vulnerability scanning identifies potential issues, while penetration testing validates exploitability through controlled attack simulation.

Q3. Are AI systems tested?

Yes. AI models, RAG pipelines, APIs, and prompt security are included.

Q4. Who authorizes testing?

Executive Management and the Cybersecurity Department.

Q5. What happens after testing?

Findings are remediated, verified through retesting, and formally closed.

---

15. Revision History

Version	Date	Description	Author
v1.0	June 2, 2026	Initial Penetration Testing Standard	Security Assurance Team
v1.1	June 20, 2026	Added AI Security Testing Requirements	AI Security Team
v1.2	**July 24, 2026**	**Enhanced Testing Methodology, AI Assessment Controls, Reporting Standards, and Verification Process**	**Cybersecurity Department**

---

16. Document Approval

Field	Details
Document ID	**AB-CYB-010**
Document Title	**Penetration Testing Standard**
Department	Cybersecurity & Security Assurance
Version	**v1.2**
Classification	**Restricted**
Document Owner	Penetration Testing Lead
Approved By	**Sami Khan – Chief Executive Officer (CEO)**

Field	Details
Approval Date	**July 24, 2026**
Next Review Date	**July 24, 2027**

Document Control

Attribute	Value
Document Status	Approved
Distribution	Cybersecurity, Security Assurance, IT Operations, AI Engineering, Development Teams
Language	English
Storage Location	Aegis Bank Document Management System (DMS)
Retention Period	7 Years
Supersedes	Penetration Testing Standard v1.1

End of Document

Aegis Bank
Enterprise AI Decision & Knowledge Platform for Modern Banking

© 2026 Aegis Bank. All Rights Reserved.
